

.....
1

FIRST: Notification of personal data security breach.

.....
1

SECOND: Preliminary investigative actions 11/07/2022.

.....
6

THIRD: Initiation of sanctioning procedure.

.....
32

FOURTH: Allegations to the initiation agreement.

.....
32

LEGAL GROUNDS

.....
35

I Competence

.....
35

II Expiry of the procedure

.....
35

RESOLVES:

.....
37

From the procedure instructed by the Spanish Agency for Data Protection and based on the following
BACKGROUND

FIRST: Notification of personal data security breach.

On 27/05 and 27/06/2022, a personal data security breach was reported to the Division of Technological Innovation of this Agency by the GENERAL DIRECTORATE OF COORDINATION OF STUDIES as the data controller (SECRETARY OF STATE FOR SECURITY-MINISTRY OF THE INTERIOR) with NIF S2800109G (hereinafter, the respondent).

In the written forms received regarding the notification of the breach, the following is reported:

On 27/05/2022, according to the form: "initial notification" "for the purposes of compliance with the notification deadline established in the GDPR. Within a maximum period of 30 days, additional information will be notified. Otherwise, the supervisory authority will consider this notification COMPLETE," it is indicated, among other circumstances:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

- It consisted of the theft of a laptop and a corrupted USB drive containing information on police actions that were being used for studies on "prevention and detection of crimes," without the data being securely encrypted, anonymized, or protected in such a way that it would be unintelligible to anyone who might have had access, and individuals can be identified.
 - In terms of affected individuals: Basic data (e.g., name, surname, date of birth), Image (Photos or videos), ID card, NIE, Passport, and/or any other identifying document, regarding convictions and criminal offenses, location data, contact data, health data (other health data).
 - In response to how many people have had their data affected by the breach, it is indicated 5,000, out of a total volume of individuals for whom data is collected of 500,000. In response to whether there are members of vulnerable groups, such as survivors of gender-based violence or at risk of social exclusion, and minors, it is indicated that yes, although in the additional information provided on 27/06/2022, it is stated that no for both groups.
 - In response to the question, "Do you consider that you have taken all possible actions and consider the breach resolved?" it indicates No.
 - Regarding whether the breach has been communicated to the affected individuals, it is indicated that "they will not be informed."
 - "The incident has been reported to the police authorities," as it is considered a crime.
 - The data controller is the GENERAL DIRECTORATE OF COORDINATION AND STUDIES (DGCE), framed within the activity of "security," dependent on the Secretary of State for Security (SES), and the GENERAL SUBDIRECTORATE OF INFORMATION SYSTEMS AND COMMUNICATIONS FOR SECURITY (SGSICS), directly attached to the SES.
 - As the "date of detection of the breach, understood as the date on which the controller is certain that personal data has been affected," which is noted in the form, it indicates 26/05/2022, and in "Do you know the date on which it started?" it indicates 4/05/2022, the date of the theft of the laptop.
- In the section: "Has the incident occurred due to any deficiency or non-compliance with implemented security measures?" it is indicated that yes.

As a difference between the first and second communication of the breach, in the second, dated 27/06/2022, unlike the first, it indicates that it does consider that it has taken all possible actions and considers the breach resolved on 24/06/2022.

Attached to the document of 27/06/2022 is a REPORT signed by the DPO of the DGCE, on behalf of this, as stated, without date, titled: "INCIDENT SECURITY BREACH PERSONAL DATA PROCESSING PDYRH (missing persons and human remains)." As background, it explains that to the initial notification of 27/05/2022, it is

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/37

On 30/05/2022, a communication was received from the AEPD in which it was considered that the information provided was not complete, as an investigation by the data controller regarding the breach is still ongoing to determine the causes, circumstances, and scope. A deadline of a maximum of 30 days was granted to complete the information, and it was warned that "upon expiration of the deadline, the breach will be assessed with the information available, without prejudice to any actions that may be taken."

The report expands on the notification of the breach. It indicates, in summary:

- The SES and its dependent governing bodies have a procedure in place for when a breach occurs. Following the entry into force of Order INT/424/2019, of 10/04, on information security policy, on 2/12/2020, it sent to all bodies for which the DPD of the SES is designated the formal action to be taken when a personal data security breach occurs, including the update of the approval of LO 7/2021 of 26/05, on the protection of personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and the execution of criminal sanctions (hereinafter LO 7/2021), through the transfer of a new procedure on 15/02/2022. They state that they are attaching ANNEX 1, although it is not included.

- It explains the competencies and entities that depend on the SES, in accordance with the regulation of the organic structure, and Order INT 429/2019 of 10/04, which approves the information security policy. It adds that the GENERAL SUBDIRECTORATE OF INFORMATION SYSTEMS AND COMMUNICATIONS FOR SECURITY (SGSICS) is also involved in the facts.

It explains and details the competencies of the DGCE, which encompasses various areas. To this end:

- Promote the participation and collaboration of the University and institutions and research personalities in the development of the activities and functions that correspond to it (art 5 bis and 1.6 of Royal Decree 146/2021, of 9/03, which amends Royal Decree 139/2020, of 28/01, which establishes the basic organic structure of ministerial departments, and Royal Decree 734/2020 of 4/08, which develops the basic organic structure of the Ministry of the Interior). For this purpose, they have the "AREA OF 'GENDER VIOLENCE, STUDIES, AND TRAINING' (VGEF)" in which the participation of technicians, scientists, and interns in projects, actions, and activities of the Secretary of State for Security is formalized.

- The centralized management for the effective and permanent coordination of the missing persons system, through the NATIONAL CENTER FOR MISSING PERSONS (XXXX), attached to the AREA OF THE STATISTICAL SYSTEM AND VICTIM SUPPORT (SEAV).

- It also details the functions of the SGSICS, which has competence over the security of information systems.

- It indicates that the security incident occurred regarding actions carried out by XXXX, which are covered by the processing of the PDyRH file, whose responsible party is located at C/ Jorge Juan, 6, www.aepd.es, 28001 – Madrid, sedeagpd.gob.es.

4/37

The entity responsible for the processing is the DGCE. It provides information regarding its content registered in the Register of Processing Activities (RAT) under LO 7/2021, stating:

1. Purpose: "Processing activities necessary for the investigation of the identity of missing persons and unidentified bodies/human remains in order to detect, prevent, and investigate crimes, thereby implementing collaboration between national and regional security forces."

2. Legitimacy of the processing: Organic Law 2/1986 of March 13, on Security Forces and Bodies, Criminal Procedure Law, and Article 11 of Organic Law 7/2021."

3. "Source of the data": "Police proceedings, missing persons, name, surname, ID number, sex, date of birth, place of birth, address, physical description, biometric data, genetic data, photographs.

Images of fingerprints and photographs imported from the ID file. Complainants: Name, surname, ID number, sex, date of birth, place of birth, address, and phone number."

- It states that:

1. "The work for which personal data was necessary was aimed at developing a predictive tool for estimating the risk of disappearances called SERDESVI - System for Estimating the Risk of Violent Disappearance - which would be used to prevent or detect criminal offenses in these cases."

2. "The person responsible for the incident is not personnel from the Ministry of the Interior; they are a researcher (collaborator) within the structure of the DGCE with various legal 'statuses' in the development of this and other similar tools. This collaborator had signed a confidentiality and information security document."

- In part III, the final section of the same report, titled: "Communication of the incident and possible breach," it indicates:

"The collaborator who suffered the theft reported it to '(...)' (not specifying which one) on 4/05/2022,"

"without specifying the content of the information that could be contained in the stolen devices." "On 6/05/2022, after being requested for more information," "he expanded the complaint and indicated that the device could contain police information."

Following this revelation, the USER SERVICE ATTENTION DEPARTMENT (CAU) informed the ICT INFRASTRUCTURE AND SECURITY AREA of the SGSICS about these events, which initiated an investigation to clarify the circumstances of the device theft, gathering all available information regarding the events that occurred. "Given the difficulty of proving what information was contained in the stolen devices, at the moment it was determined that they contained personal data, communication was made with the DPD of the SES and with the data processing manager (RTR) of the DGCE. The

communication of the security incident that could constitute a 'Data Protection Breach' was forwarded to the DPD of the SES on 26/05/2022, at 10:50 hours."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/37

"According to the instructions from the RTR, the DGCE, due to several unresolved issues, on Thursday the 26th, proceeded to request information from the AREAS (VGEF and SEAV) that could have been managing the treatment(s) that may have led to the breach." These areas, "from which the PDYRH treatments, VioGén SYSTEM, and TRAINING and EDUCATIONAL COOPERATION ACTIVITIES with Universities would functionally depend.

"On the same day, the responsible party requested the DPD of the Secretary of State to assess the facts that have come to their attention within the framework of their functions and to collaborate in determining possible vulnerabilities and improvements to be made to rectify what occurred and prevent a similar danger from materializing again. Based on this, they require all affected parties to meet with them for this purpose on the following Monday, May 30th.

The heads of the affected areas respond to the information request through communication with the DPD."

"In correspondence with the information conveyed by the VGEF Area, it is only concluded that the incident did not affect any treatment of that Area, although the person who caused the incident was framed in the 'TRAINING AND STUDIES AREA,' and 'From the information sent by the SEAV Area, a summary of the breach can be assessed, and from the very first moment, initial measures are applied to rectify possible vulnerabilities and increase the level of security of the treatment.'"

"The person responsible for the Treatment, through this DPD, in accordance with legal and procedural provisions, makes an initial communication regarding the data security breach on the same day, May 27th, at 14:06 hours."

"The stolen data that was processed for the purpose of developing the aforementioned tool came from police proceedings and contained basic data, images, identity documents, information on criminal offenses and convictions, location data, and health data. As of today, after verifying the exact documentation, (...), it should be noted that the stolen information did not include biometric data or data of minors."

"...the SES implements on all its users' computers (...), both laptops and desktop PCs, that is, the equipment has the solution (...) and the XXX solution from the manufacturer XXXXXXXX called XXXXX. The logs obtained from the consoles of both solutions indicate that the last communications established by the stolen equipment took place minutes before the time when the user reports that the device was stolen on the day XX/XX/2022, in the case of XXXXXXXX at 19:39:17 hours and in the case of XXXXXXXX at 19:11:00 with the user XXXXXX logged in, with no other communication being recorded from that moment until today, indicating that whoever stole the device has not connected it to the Internet since then, as otherwise, the agents installed on the equipment of the mentioned XXXXXXXX protection solutions would have automatically sent a report to their respective management consoles." "It indicates that there is no record of any harm materializing that affects the rights of the interested parties" and that "all flows have been analyzed."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/37

data contained in the referred treatments, designing a system based on the increase of technical and organizational protection measures in all treatment activities concerning the individuals involved in each of them and in the information being handled. A system is being developed that does not allow, under any circumstances, access to data that is not fully anonymized by external personnel carrying out their work in the DGCE.

They consider that the treatment is covered by Organic Law 7/2021, therefore they believe that: "The data controller understands that communication to the interested parties should be omitted as it is believed that communicating it would hinder ongoing inquiries and police investigations, cause serious harm to public safety, and is necessary to protect the rights and freedoms of third parties."

SECOND: Preliminary investigation actions 11/07/2022.

On 11/07/2022, the Director of the AEPD, as a consequence of the notification of the personal data breach communicated, urged the General Subdirectorate of Data Inspection to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

On 16/09/2022, the DGCE was requested:

1- Internal procedure for communicating security breaches

In their writing, they indicate the existence of an internal procedure for the communication of security breaches (adapted to Organic Law 7/2021) which was provided as Annex I; however, this attachment could not be located. A copy of this is requested.

On 06/10/2022, the Data Protection Delegation of the SES responded, accompanying various annexes from different bodies of the SES.

They provided a copy of the "internal protocol for the management of breaches," effective from 14/03/2022, updated to LO 7/2021, with a previous version dated 27/11/2020. In it, it is indicated among other aspects:

- "It must be determined whether the detected security breach poses a risk to the rights and freedoms of the affected individuals. This step is key, as it marks the difference regarding whether the security issue needs to be notified to the AEPD or not. To know if the attack poses a risk, it will be necessary to analyze whether it falls under one of the criteria and examples included in Recital 75 of the GDPR or in the Guidelines 01/2021 of the EDPB," on examples of notification of personal data security breaches, adopted on 14/12/2021.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/37

- "The data controller must establish a record in which the location, date, and time of detection of the security breach are recorded, as well as the systems, data, and equipment that have been affected. Once the breach is resolved, the record must also include the solution or the procedures established to repair or mitigate the security issue."

- "1. When to notify: As soon as the data controller becomes aware that a personal data breach has occurred, they must notify the competent Supervisory Authority, when it is likely that the breach poses a risk to the rights and freedoms of individuals. If applicable, this must be done without delay and no later than 72 hours thereafter, including the hours that have elapsed during weekends and holidays."

- "4. Who must notify: When a data controller is aware that a personal data breach may pose a risk to the rights and freedoms of individuals, they must notify the Spanish Agency for Data Protection."

- "The notification of a personal data breach to the supervisory authority is the responsibility of the data controller in accordance with Article 33 of the GDPR, Article 39 of the LOPDP (LO 7/21)..."

- "The data controller must necessarily inform their Data Protection Officer, who can advise and assist them in the process."

- "There is also a section on 'communication to affected individuals,' which notes: 'In the case of processing where Organic Law 7/2021 of 26/05 applies, communication to the data subject may be postponed, limited, or omitted subject to the conditions and for the reasons provided in its article.'"

2- Updated copy of the incident register documenting the security breach. Provides a copy of ANNEX II: a file that, when opened, is titled: "additional information on laptop theft," version 3/10/2022 from the SGSICS, which is responsible for the management, administration, and IT security of the technological infrastructure with which the Ministry of the Interior provides its services. This report also addresses

other issues raised in other paragraphs requested by the Inspection Service.

It is stated that on 6/05/2022, the CAU informed the ICT SECURITY AREA OF THE SGSICS of the "theft of a laptop belonging to the Ministry of the Interior, assigned to personnel providing services at the headquarters of the SES, at Calle ***DIRECCIÓN.1, Madrid," and that they initiated an investigation.

It indicates that it provides as "a copy of the updated incident register documenting the security breach:"

- Doc.1.- Extraction from the register and tracking of the incident in the incident manager of this Subdirectorato (JIRA ticketing tool). It does not appear in this annex II, but is found within Annex IV (which contains several documents from different sources) in this case, sent separately by the same SGSICS titled "Report of C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/37

security regarding the theft of a laptop belonging to the National Center for Missing Persons" and it is an email from the SGSICS dated 09/05/2022, 10:48, indicating:

"Subject CAU 2019 a JIRA is opened in Systems Security due to the theft of an HP laptop." It is preceded by another from the same day in which the extension of the complaint dated 06/05/2022 is also sent.

- Doc.2.- Extraction of the incident record in the tool of (...). It does not appear in this annex II, nor is it noted in any of the sent documents.

- Doc.3.- Extraction of the incident record in the tool of (...). It does not appear in this annex II, nor is it noted in any of the sent documents.

3- List of the individual who had the laptop and the stolen USB device (with personal information), documentary accreditation of their link with the (DGCE) is requested, providing copies of possible agreements, contracts, or other legal instruments existing for the formalization of this external personnel in charge of processing, as well as the signed confidentiality agreements.

It states that it provides a copy of information provided by the AREA OF STATISTICAL SYSTEM AND VICTIM ASSISTANCE (SEAV), specifically in annex "contract" file number 21/027 which refers to:

- Copy of TECHNICAL SPECIFICATIONS DOCUMENT "for the contracting of scientific research on the creation and validation of a predictive tool and risk assessment of disappearance with fatal outcome," dated 31/03/2021, (signature DGCE).

It consists (point 1, object) of a "review, reading, data extraction, and analysis of documented information in a sample of 2000 reports of missing persons at different points. The study of documentary data from a significant sample of disappearances (2000) selected by the officials stationed at XXXX through the PDyRH system (missing persons and unidentified human remains).

The potential usefulness of the identified variables will be explored to create:

a) a standardized model for reporting, collecting information in cases of disappearance with empirical support

b) a predictive tool for the scenario or type of disappearance most likely and risk assessment of fatal outcome, and

c) an executive guide for the initial response of police action based on evidence."

All this with the aim of validating the current classification of disappearance scenarios, identifying new indicators, and advancing predictive capacity." "All cases must be closed and clarified by the police and integrated into the System of Missing Persons and Unidentified Human Remains (PDyRH). This involves the work:

a) The collection and detailed study of all police, psychosocial, and criminological documentation of each case.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/37

b) The systematization of the information collected in a database created for this purpose, as well as the analysis of the data."

In "work team," it is indicated that the contractor must necessarily have a principal investigator.

In point 3: "By the Secretary of State for Security – General Directorate of Coordination and Studies – National Center for Missing Persons and Study Area, a Coordinator of the study will be appointed, who will maintain the necessary communication with the work team designated by the contracting Institution to promote maximum coordination between the tasks and activities to be developed."

"7. SECURITY AND CONTROL REGULATIONS

All personnel from the contracting Institution involved in the work must comply with the security, control, and internal regime regulations of the police and penitentiary centers and dependencies where they have to work."

Clause 8.2: "confidentiality and data protection regarding data related to the activity of the Administration that must be provided." It is indicated that the contractor: "will only process personal data to which it has access according to the instructions of the Study Coordination and will not apply it for any other purpose."

"9. OBLIGATIONS OF THE ADMINISTRATION

- Facilitate the selection of cases to be reviewed.
- Facilitate access for research personnel to the police documentation of those involved in the cases under study.
- Facilitate access for personnel to all dependencies of the Ministry of the Interior where they have to work, without prejudice to the necessary control for security reasons.

The execution period is a maximum of 5 months.

- Copy of the DOCUMENT OF PARTICULAR ADMINISTRATIVE CLAUSES, service contract "open simplified," referencing in point 27 "security and confidentiality," and in point 28 "processing of personal data" in which access to cases involving individuals as authors of crimes and victims is recognized. It is indicated that the contracting entity will be considered as "data processor" and among other things, must "apply measures that guarantee the security of the data."

"In the execution of the contract services, the following personal data are considered, the responsibility of the contracting entity, which will provide the necessary data to the contractor:

- The personal data selected by the contracting entity.
- The personal data contained in police proceedings and those provided in interviews with the agents of the Security Forces and Corps themselves.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/37

- The personal data obtained during interviews with victims and offenders of crimes.

In any case:

- The contracting entity will be considered the data controller.
- The contractor will be considered the data processor of this data and it will not be considered that there is a communication of data.

a) The data processor will only process the data according to the instructions of the data controller, will not apply or use it for purposes other than those stated in the contract, nor will it communicate it, even for its conservation, to other persons. Maintaining due confidentiality of the data at all times.

b) The data processor must adopt the necessary technical and organizational measures to ensure the security of personal data and prevent its alteration, loss, processing, or unauthorized access, taking into account the state of technology, the nature of the stored data, and the risks to which they are exposed, whether arising from human action or from the physical or natural environment.

c) Once the contractual service has been fulfilled, the personal data must be destroyed or returned to the data controller, as well as any media or documents containing any personal data subject to

processing.

- In the event that the data processor uses the data for another purpose, communicates it, or uses it in violation of the stipulations of the contract, it will also be considered responsible for the processing, being liable for any infringements it may have personally incurred.

- In point 17, as environmental conditions, it is indicated that: "the provision of services will be carried out using computer means, avoiding physical paper support except in essential cases."

- Copy of the formalization of the contract with the Foundation of the Autonomous University of Madrid, awarded on 23/06/2021.

- Copy of the invoice issued on 13/12/2021.

4- In relation to the development of the predictive tool for which the personal data obtained was necessary, information is requested regarding its operation, providing details of the types of personal data needed as input to train the algorithms, those needed for validation or testing, as well as details of the prediction it makes and the use that would be made of it, also indicating the existence of profiling. The response document states that information provided by the Statistical System and Victim Assistance Area (SEAV) is attached as Annex III. This annex, dated XXXX, responds to several of the questions raised in the inspection request, and is signed on 4/10/2022. After framing its dependency on the DGCE, its creation was by C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/37

Instruction 2/2018 of 5/02, and its functions, details that in 2019 it launched a study "to establish reliable and effective risk assessment methods that help police investigators guide investigations from the moment a report of disappearance is received." "With the support of university personnel, a working group was previously created to determine the factors that influence a person's disappearance, with the aim of creating an effective tool that allows investigators to estimate the most probable scenario in the event of a new report of disappearance, as well as the type of outcome that is most likely."

The 2021 contract is a continuation of this work. It refers to section 11 of the "justification report" in which the processing of data by the contractor is included, indicating access to data related to victims of disappearance crimes and perpetrators of crimes.

It informs that on 1/07/2021 the contract was awarded to (...).

It states that in accordance with section 5 of the Technical Specifications, personnel for the service was anticipated, and the University hired D. A.A.A. (COLLABORATING RESEARCHER IC hereinafter) and B.B.B. (XX hereinafter) to lead the work at the XXXX facilities. Confidentiality and data protection are also mentioned regarding the data to be provided to the contractor for the performance of the agreed services, extendable to the contractor's collaborators, who will sign the confidentiality commitment.

The Foundation proceeded to hire the work team for the development of this tool.

"The necessary documents for the research team for the study and development of the contract subject to tender were requested from the Security Forces and Corps (FCS) by the XXXX, being sent to the official email created for this purpose ***EMAIL.1, a secured account managed by the SGSICS." The use of this email is framed, due to the purposes it is dedicated to, within the Regulatory and Studies Section of the XXXX, to which only its head has access. Upon receipt of the documents, they were stored in the official secured "XXXXX" of the SGSICS, called XXXXXX. "The operation of this space is secured, and access (...)."

"The procedure for viewing the documents was as explained below: When the research team required any documentation, the XXXXXXXXX on a desktop PC in the room set up for the work at the XXXXX headquarters accessed the cloud, and only the necessary documents for the study they requested daily were shown to them, closing the cloud again and leaving the documentation for their analysis and study. The computer equipment used by the research team was provided by the XXXX with the established security access measures. It is noteworthy that for (...), managed and secured by the

SGSICS. The computer terminals used for access to XXXXXXXX by the research team were of the type of (...) owned by the Secretary of State for Security, managed and controlled by the XXXXX.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/37

One of the clauses of the contract in the technical specifications document, 8.2.2., states that the awarded party must ensure compliance with the requirements established by the personal data protection regulations concerning the personal data to which it will have access:

- "It will only process the personal data to which it has access in accordance with the instructions of the Study Coordination, and will not apply or use it for any other purpose."

On 13/12/2021, the (...) concluded the contract, delivering the work carried out by the multidisciplinary research team, with XXXX having no further legal business relationship with the Foundation or with the researchers of the work team from that date. An invoice was issued on that day (13/12/2021).

"The resulting predictive tool (application) is being implemented in the PDyRH System, as support for the decision-making of the researchers."

"From subsequent information received, which was included in the first report to the DPD of the SES mentioned, it was reported that it had been learned that the previous (...), Studies and Training (...), allowed the extraction and storage of documents on an official laptop, without the knowledge of the officials who had participated in the process of creating the predictive tool. These details were not known to the responsible parties of XXXX until the day after the theft of the backpack in which, among other items, was the laptop assigned to that responsible party, at which point they learned that XXXXXXXX, Mr. XX, had stored information on that laptop, property of the SES, which he used – according to his own statements – for other personal uses, and that he took out of the facilities without any control, and that he had been doing so for an undetermined period. All of this was also unknown to the responsible parties of XXXX."

5-Copy of the RECORD OF OPERATIONS of the information system that processes personal data (as specified in Article 33 of Organic Law 7/2021).

Specifically, the record of those operations related to the consultation and communication of personal data to the data processing officer, victim of the stolen devices.

The Data Protection Delegation states in its response:

"The specific information that produced the security incident and the personal data breach was not extracted from an information system and therefore records cannot be provided from the XXXXX system or any other." Information is provided in annex XXX regarding the primary extraction of the data, although it is unknown what the organizational or technical process was that led to the data ending up in the possession of the person who suffered the theft. As of today, the record of operations as such has not been fully implemented in the information systems. The security dimensions, authentication, and traceability are accredited, although the inclusion of justification and the name in the automated records has not yet been incorporated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/37

the person or identity of the recipients for the operations indicated in Article 33 of the LOPDP (collection, alteration, consultation, communication, including transfers, and combination or deletion). " It should be noted that such Annex XXX is not included.

- It expands the information in the aforementioned Report of 3/10/2022 from the SGSICS XXXXXXXX, which indicates:

"According to what was communicated to this Subdirectorate by the liaison personnel of XXXX, the hard drive of the stolen laptop contained an extraction of PDyRH from the year 2019 (database) of

which this Subdirectorate has no record regarding its existence or origin.

"However, regarding this extraction, the following clarifications are necessary: The PDyRH system collects data on unidentified corpses and human remains investigated by the Spanish Security Forces and Corps, as well as all reports of missing persons, information with which the system subsequently performs a comparison. In the event of finding any match, it is communicated to the involved Corps and a collaboration protocol is initiated. The system has three environments: Production with six application servers and two database servers, XXXXXXXX with XXXXXXXXXX of applications and XXXXXXXXXX of database, and XXXXXXXX, with XXXXXXXX dedicated to the project. The information stored in the PDyRH system is obtained through the fields enabled in the application, which is extracted from police reports either automatically or manually in cases where the police system is not integrated with the PDyRH system. The reports are in no case found in the application servers of PDyRH or in the database. Thus, in the PDyRH system, there are only fields with data from the report and structured information that complements and is cross-referenced for comparison, with the reports remaining stored in the corresponding police systems."

They state that the SGSICS has the following responsibilities regarding this PDyRH system:

1. Definition of the data model, development, and maintenance of the system.
2. Enabling access for users of the Security Forces and Corps.
3. Incident management.

It mentions the different State Security Forces and Corps that have access to said application, and, "in addition, to the database, the authorized personnel of XXXX, responsible for data processing."

Users connect to the application through a dedicated and secure network, called "Police Network" (network managed by the SGSICS)."

The SGSICS has no record that a request has ever been directed by the data processor, requesting a data extraction from the application or the PDyRH database that could correspond to the information contained in the stolen device.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/37

There is also no record, nor any evidence or alert, that this computer system has suffered any security breach.

To this end, the application logs and the database logs from November 21 to November 30, 2021, are attached, and the rest of the stored logs are made available for any inquiries deemed appropriate.

Furthermore, it should be noted that on November 30, 2021, a request made by the Head of the Studies Area, Gender Violence Area, Studies and Training of the General Directorate of Coordination and Studies, regarding the extraction of police reports from the VioGén system was attended to by this Subdirectorate. This is as stated in the information provided by the interlocutor from XXXX, related to PDyRH, and was addressed by the department responsible for the data.

Given that the requested information was not located in the database of the system, but rather the database only contains notes on the paths where the other documents are stored, the following operations were carried out:

On November 26, 2021, a request was made by the area responsible for the VioGén System, personally and via email through the Head of the Studies and Training Area, previously authorized by the person referred to in the email as "XX," for a copy of the police reports from the year 2019. This is recorded in the email thread that appears as evidence 10 of the original report of this incident. It is included as ANNEX II.

"Given the volume of reports to be recovered, 62,409, several of which were damaged, and due to the impossibility of extracting them directly from the VioGén application (web environment), SGSICS offered the possibility of extracting these reports directly from the server" and "extracting the selected files using the SFTP tool." "This operation did not leave an audit trail in the VioGén web application."

"For record and verification purposes, an audit log from the date of extraction is attached as Doc. 4." It indicates that "what is recorded in the application audit is:

A list of complaints and facts associated with each complaint, with information on the 'identification of the victim and perpetrator of the case, and consultation of the complaint file, -not of the file with the report -although there may be a link to that file if it exists for download without it being recorded that it does in that case.'

"After the extraction was carried out, it was delivered in person at the SGSICS facilities in El Pardo to the Head of the Studies and Training Area on November 30, 2021," containing the reports referred to in the attached document referenced as Doc. 5.

Neither document 4 nor document 5, which is cited, has been received.

- For its part, in ANNEX III, originating from XXXX dated October 4, 2022, a response is provided, among other points, to this, not addressing what was questioned but referring to the activity log of the processing, reiterating that the processing activity affected by the theft of the laptop from the Ministry of the Interior is the activity "Missing Persons and Remains System."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/37

"Unidentified Humans" (PDyRH), and reiterates the content of the same which was already included in the DGCE report accompanying the second notification of the breach.

It states that "However, it has been established that the laptop not only contained personal information extracted from the PDyRH system (where data on missing persons and unidentified human remains are stored along with the reports of disappearances received by the FCSE), but also other sensitive police-related information, such as police reports of disappearances and homicides that have already been clarified, audios and videos of testimonies from family members, victims, aggressors, and other police material related to the investigations. To support the processing of this information for the purpose of conducting scientific studies, they have proceeded to update the RAT, as of 12/09/2022, including the new activity called SES-STUDIES, detailing its structure.

6- Regarding the internal investigation conducted on the incident, the following is requested:

- o A copy of the documentation existing in the report filed by the victim of the theft (both to the Area to which they belonged and to the CAU on the days 4 and 6/05/2022).

- o A copy of the documentation obtained by the Infrastructure and ICT Security Area (from the SGSICS) during the investigation of the incident (which was initiated after the new data provided by the victim on 6/05/2022).

- o A copy of the documentation sent by the Areas that managed the possible treatments that led to the breach (Areas VGEF and SEAV), following the urgent request made on 26/05/2022 and in accordance with the instructions of the Director General of Coordination and Studies.

It responds that it is attached in ANNEX IV, which contains various documents, part of which was prepared by the SGSICS, providing:

- A copy that certifies the first report filed by the user with the National Police on 4/05/2022. In it, it is indicated "that the speaker belongs to the Ministry of Interior-National Center for the Disappeared," that among the items contained in the backpack, there were folders with the logo of "XXXX" containing police-related information of third parties," "it notes that the computer has an access password and contained files with confidential information," that it cannot provide the serial number of the computer but will make an extension to provide more data.

- In the extension report of 6/05/2022, it provides the identification data of the brand and model of the computer and serial number, adding as objects, a yellow pendrive, indicating that "the computer does not have an access password as initially stated, so anyone could have access to the information."

The SGSICS accompanies a "Security Report on the theft of a laptop belonging to the National Center for the Disappeared," linking it to ANNEX II referred to in point SECOND, although this ANNEX 4 is broader, although it lacks a date.

It indicates that the laptop from the Ministry of Interior was assigned to the personnel providing their services at the SES headquarters, ***ADDRESS.1 in Madrid and that from the investigation initiated

from 6/05/2022, the laptop was in the possession of XX, C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/37

a person who developed projects in XXXX, describes, brand, model, and serial number, and who "did not have an access key so that anyone could access the information," a 500 GB hard drive and 8 GB of RAM, and identification of the hostname-name by which the device is identified- and had configured the user "XXXXX" with administrator privileges and "whose account lacked a password," there was also no BIOS boot password (which would have prevented it from being started by anyone who did not know those credentials). The 500 GB hard drive was not encrypted, "so access to the information contained is completely free by simply turning on the device."

They assert that the equipment was initially awarded by SGSICS (on 29/11/2018) to Mr. C.C.C. (XX hereinafter) who, at that time, was head of (...) -of the DGCE, but who at the time of the theft was no longer providing services in the department. Subsequently, on 2/12/2019, the computer was reallocated by the User Support Department of SGSICS, with no other record regarding new allocation or intervention on the stolen computer to date. "According to reports from XXXX, the equipment was under the responsibility of another National Police Officer from the XXXXX Area." (who is identified by name and surname- and who turns out to be the current head of XXXXXXXXX).

They assert that the stolen equipment was part of an initial batch of 6 laptops requested in 2017 for internal training activities that required laptops with the administrator user enabled and without credentials, and that were delivered to be used exclusively within the headquarters. It was later assigned to the head of the VGEF Area on 29/11/2018, but in any case was intended for internal use within the Area's premises. In the incident management system of SGSICS, there is a record entered by the CAU regarding this, which states:

"Received the equipment. Once the course is finished, 5 laptops remain in the cabinet waiting for collection. Following instructions from XXXXX, one laptop has been assigned to C.C.C. 'I open another ticket with this fact. Regards, XXXXX.'"

"The purpose and use of the laptop was the development of scientific research tasks and a predictive tool since 2018, tasks that were performed by XX under the supervision of the staff of XXXX, 'without a specific person under whose responsibility these tasks were developed.'"

They assert that in SGSICS-XXXXX, there was no record of authorization to remove the computer from the headquarters and that the user Mr. XX himself stated that he was not aware that this could not be done, and that he does not remember if when he joined in 2017 he was told that he could not take it out of the headquarters.

They state that "According to the documentation signed by XX, there was a configured user on the stolen equipment for access to the Wifi network SESXXXXXX WLAN_XXXX, intended to meet the need for Internet access through wireless devices for users working at the SES 'XXXXXXX' headquarters, where the National Center for Missing Persons is located. A copy is provided in evidence 8 signed on 24/06/2021, although there is no reference to the equipment for which it is."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/37

requests. The "specific information security standards for the use of the wifi network SESXXXXXX within the SES" are also associated, which indicates that "it is intended for the service of personnel from the Cabinet of Coordination and Studies for Security at its headquarters in XXXXXXXX, and access is restricted to users who perform their functions at said headquarters. Occasionally, users outside the SES may be enabled to use this connection, provided that the needs of their work or function require it."

Through the application XXX -open web Access- using the Internet connection, access was made to the email inbox ***EMAIL.1, which was shared with other users of a similar profile within the XXXX.

The user access to the aforementioned website has been disabled.

It is stated that the stolen computer did not have access to the SES domain where sensitive information could exist, as this could only be done from (...) to which specific security policies applied, such as the blocking of USB ports.

It is claimed that the SGSICS has no record of how the information contained in the stolen equipment was provided to the user, stating that it is the responsibility of the official in charge of the user to control their functions and the information provided to them. They also state that at no time were they requested by XXXX or by the person awarded the computer to implement measures for the protection of information or the device during its transfer or use of police-related information or containing personal data outside the SES premises.

The SGSICS states that user D. XX is not registered in the corporate user management applications of the Ministry of the Interior ("...") and therefore does not have an individualized and unique user account for the domains of the Secretary of State, where sensitive information could exist. They claim that this is the reason why there is no signed document by the user or their assigned supervisor informing them about the applicable good practice regulations for their position. Although they claim that there is a Confidentiality Agreement document from XXXX signed by the user dated 14/12/2017, they provide a document (evidence 7), with a mention on a single page, SES logo, stating "4. signature protocol: 'I have read the agreement regarding the confidentiality policy of the Subdirectorate, and I accept its content in the terms expressed here'" without these terms being specified, without knowing the terms. It indicates that the SGSICS was not aware of this (it was sent to them by XXXX via email on 17/05/2022).

From the SGSICS, it is stated that, according to statements obtained from the responsible parties of XXXX and from D. XX himself, this user currently has no contractual relationship with the Ministry of the Interior, but rather performs development tasks for a predictive tool as part of a XXXXXXXXX project of the Institute of (...), to which the user belongs, and that although there is a general training agreement between UAM and SES, there is no record that he could be working under the protection of the aforementioned agreement through the formalization of a collaboration agreement or clause.

However, with the information available to the user support department of the SGSICS, SES contracted on 11/06/2019 with UAM for the review and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/37

analysis of cases of disappearance of violent etiology, and subsequently, on 23/06/2021, the contracting with XXXXXXXX of the UAM for the creation and validation of a predictive tool and risk assessment for disappearance with fatal outcomes.

In relation to the information compromised with the laptop, it is stated that, according to the statements of the responsible parties of XXXX, the information contained in the hard drive was as follows:

1. 1140 clarified police reports on disappearances of different etiology used for XXXXXXXXX.
2. 800 clarified police reports on disappearances used for XXXXXXXXX.
3. 60 clarified police reports on homicides with investigative proceedings from the Judicial Police and technical police ocular inspections.
4. Recorded interviews with Judicial Police agents, family members, and close associates of victims and aggressors, as well as videos recorded with the latter while in prison.
5. Extraction from the PDyRH database from the year XXXX.
6. Database used for the preparation of the work: "XXXXXXXXXX of cases".
7. Databases used for the preparation of the published work: "(...)"
8. Databases used for the construction of the XXXXXXXXX, and technical report on its construction.

According to the statement of Mr. XX, among the storage devices stolen, there was one "labeled with CEPOL that contained personal information." "Another of the USB drives was corrupted and inaccessible. The rest of the USB drives, according to the user, were empty." In the yellow folders that were also stolen with paper documentation, according to the initial statements of the user, it contained

police information; however, these statements were later corrected in the second report, asserting that they contained invoices in the name of XXX related to the trips within the framework of the project in which he was working and not sensitive police information.

SGSICS itself states that, after the internal investigation carried out, it concludes with the existence of several deficiencies that arose both at the technical and operational and organizational levels, specifically they state the following:

At the organizational level, they assert that:

1. There is no record of the designation of a direct responsible official for Mr. XX as an external user who performed his work at XXXX.
2. There is no record that the user was informed of the regulations applicable to his position, of the actions he is authorized to carry out, and those he is not authorized to perform with the means and resources made available to him. There is also no record of the user's acceptance and knowledge of these rules, completing the signature protocol and ratified by his supervisor in the SES.

At the operational level:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/37

1. There is no record of how, by whom, and under what precept the information contained in the stolen device was delivered to the user.
2. The exit of devices containing high-level or even critical information was allowed, especially when the device containing it lacked basic or elementary protection measures that would make it inaccessible to unauthorized personnel.
3. The user remained in a public establishment with a device containing confidential information without adopting adequate surveillance measures.

At the technical level:

1. The users configured on the stolen device were the user "XXXXXXXX" and the user "XXXXXX" who had administrative privileges and lacked an access password. The device lacked passive protection measures such as a BIOS password, hard drive encryption, or the existence of disk partitions protected by encryption.
2. In addition to the user from whom the computer was stolen, there were, according to information provided to users, a total of three generic users (Interns 1, 2, and 3 respectively) with access to resources of the domain XXX-mir.es and sharing mailbox ***EMAIL.1, which does not allow for the traceability of actions.
3. It is understood that this must be communicated to the AEPD.

By SGSICS, the following evidence is attached:

- Copy of the internal document, evidence 3 "Movement of Material" from the CAU that certifies the assignment of the laptop on 29/11/2018, due to "failure of the one assigned." No annotations regarding its configuration are noted.
- Evidence 4: "historical action on the stolen equipment," from 2017 to 2019. It is noted that it was configured for the first time in 2017 and was re-platformed in 2019.
- Evidence 5: "remodeling of the stolen equipment," indicating "user of the equipment with administrative privileges."
- Evidence 6, with four annotations, from 13 to 20/12/2017, one of them "configuration ticket for user XXXXXXXXX with administrator permissions and without password on each laptop," from the 13th, and noted in the last one "received the equipment, once the course is finished, 5 devices remain in the cabinet of XXXXXXXX, awaiting collection. Following instructions from P..., a laptop has been assigned to XXXXXXXX."

As evidence 9, "consoles of XXXXXXXXXX," provides screenshots of records "(...)" in which it is seen that on 4/05/2022 the last connection appears before the suspension occurred, with none afterwards. As evidence number 10, a screenshot with the email sent by Mr. XX (head of (...), address c/

***DIRECCIÓN.2) on Friday 26/11/2021 with the content

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/37

the following related to the transfer of information contained in the laptop stolen in May 2023:

“Hello team.

This morning we had a meeting with SAS and with a university in VioGén (as you already knew) and XX has given the green light to conduct these studies of reports and cases from 2019. I have called all of you, but you are not answering. How does it work for you if I come by on Monday morning starting at 10:00 AM to carry out the data extractions? The intern from XXXXXXXX who will process them will accompany me, to take them on a laptop, as we are somewhat pressed for time. It would be to recover the extraction of all cases from 2019 for a one-year follow-up (and we would see if we could also take the ones from 2020, now that we are almost at the end of the year) and the reports that can be extracted (if there are 40,000, even better).

- It refers to measures and actions “aimed at improving preventive security measures” by the gender violence studies area, as responsible for the intern students, centralizing the management of student personnel, with lists to increase control, review of updated agreements, management of the physical use of common workspaces, and assignment of a responsible tutor, review and improvement of confidentiality clauses for personnel accessing data with a guide of specific behaviors and good practices, guides for the use of resources (they provide a copy of the clause, of the good practices).

Periodic review of actions

“Signifying that the time elapsed from the notification of the theft to the submission of this report has been the necessary time to clarify and identify the scope of the incident and the sensitive information that may have been exposed.”

In the same XXXXXXXX, which contains various documentation, a report from the head of the STATISTICS AND VICTIM ASSISTANCE SYSTEM (SEAV) to the DPD is provided, dated 27/05/2022. In this report, the head of the SEAV Area states that as soon as he became aware of what happened, he informed the director of the DGCE by sending an email on 5/05/2022 at 14:25. This fact is evidenced by the provision of a screenshot of the email from the person responsible for (...), which contained the following text (with a copy to three people):

“A.A.A., good morning:

... Yesterday afternoon XXXXXXXX ... (XXXX) had his backpack stolen inside a bar in Madrid. He filed a complaint... Inside the backpack, he carried ... the HP work laptop provided by SGSICS, although, as he is not personnel of the Ministry, he did not have a key assigned to his user (only in the administrator part), as well as documentation from XXXX in paper and on Pendrives. Both the information contained in physical and digital format is related to the work he has been doing in recent years on the predictive risk tool, including police reports.

We are in contact with SGSICS to report the incident of the laptop... we are managing the matter jointly with Studies from the Violence Area of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/37

Gender, Studies, and Training to, among other things, review and improve the security procedures that University personnel working with us must use. I will keep you informed if there are any further developments regarding this matter. It is expressly stated

that

- This SGSICS was verbally informed on the same day, 5/05, with the reference noted in the computer application.

- The XXXX issued a report on 10/05/22 addressed to the person responsible for the file XXXXXX regarding the theft of sensitive documentation from a XXXXXXXXXXXX.

The report states that until 5/05/2022, neither the head of the SEAV Area nor the head of the XXXX Service was aware that the XXXXXXXXXXXX of the UAM, who was working for the XXXX, was using an official laptop not only for work related to studies supervised by the VGEF Area but also for personal and private use.

The report states that the data on the laptop included 2000 reports on missing persons with fatal outcomes from various Security Forces and from cases that had already been adjudicated.

Specifically, it states that the laptop contained, according to the inquiries of the XXXX:

- Police reports on resolved disappearances from both the National Police and the Civil Guard, as well as from the Autonomous Police, including the Mossos d'Esquadra and the Policía Foral de Navarra. It also contained databases where the information from the aforementioned reports was stored.

- Police reports on homicides resolved both police-wise and judicially and associated with a report of disappearance, from both the National Police and the Civil Guard. It also contained databases where the information from the aforementioned reports was recorded, as well as audio and video recordings of interviews with those involved in the cases (victims, aggressors, or their relatives, among other aspects).

- Databases, annual extractions of PDyRH, manuscripts of research work, justifying reports of projects, expense justification tables, and other aspects of administration and control.

The report states that the affected personal data belonged to individuals who were reported missing and had fatal outcomes, to convicted authors who were imprisoned, and to relatives and other people in their environment, with the extent of the number of affected individuals being unknown since there was no backup of the content of the laptop.

Regarding the estimated consequences, it is stated that if individuals who can interpret the content of the information access the information contained on the computer, the consequences would be unpredictable, as some of the reports known, according to the statements of Mr. XX, are from very high-profile cases (but already adjudicated).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/37

The head of the SEAV Area states that the chronology of events was as follows:

- On 04/05/2022, the laptop owned by the SES (SGSICS) that was assigned by the VGEF Area to XXXXXXXXXXX D. XX was stolen. At 22:54 hours, this same XXXXXXXXXXX filed a complaint with the National Police.

- "On 26/05/2022, an email was received in the VGEF and SEAV areas from the DPD of the SES requesting the drafting of a report on what had happened and attached the report already drafted by the SGSICS following its internal investigation." In relation to this email, the SEAV area responded with the following inaccuracies that they had detected in the attached report drafted by the SGSICS:

- ☐ That the laptop was not assigned to XXXX as claimed by the SGSICS, since it was not until 05/05/2022 that this area became aware that the XXXXXXXXXXX had been assigned an official laptop containing police information.

- ☐ That the laptop was assigned to D. C.C.C., a member of the area of (...), who left the DGCE by resolution dated 01/02/2022 without the SGSICS taking any action regarding the devices assigned to this person, and that measures should not be requested by users but ex officio by those responsible for computer security SGSICS.

- ☐ That the supervision of the work of XXXXX D. XX is exclusively the responsibility of the VGEF area, just as it is for any other personnel from universities.

- ☐ The report states that the activity of D. XX in the SES can be summarized as follows:

- He has been collaborating with VGEF and SEAV since 2017, and due to his skills and qualifications, it was decided that his doctoral thesis would focus on the aforementioned predictive risk tool to assist researchers in cases of disappearances, being under the supervision of D. XX until his cessation date.

- On 11/06/2019, a contract was signed with XXXX to carry out a detailed review of cases of disappearance of violent etiology in Spain, a task that compiled reports and interviews with agents, the victim's environment, and the aggressor.
- On 23/06/2021, a "contract for the creation and validation of a predictive tool and risk assessment for disappearance with a fatal outcome" was tendered. This contract was awarded to XXXX in July 2021, with a duration of 6 months, concluding services in December 2021.
- Subsequently, D. XX has continued to develop work for XXXX; for example, it is stated that in XXXXXXXX he represented XXXX at the conference of XXXXX "...", and attends training presentations.
- The SEAV area states that the necessary documents for the investigation team were requested from XXXX to the Security Forces, being sent to the official email created for this purpose, which, according to them, was exclusively accessible to the head of XXXX (**EMAIL.2). However, according to the statement from C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/37

SGSICS, user D. XX also had access to this email inbox, which was shared by other users of a similar profile.

- From the SEAV area, it is stated that on 13/12/2021, XXXX concluded the contract by delivering the work. They assert that from this date onwards, XXXX has no further legal business relationship with this Foundation, nor with the contracted researchers. At the time of delivery and prior to the issuance of the invoice, emphasis was placed on the obligation to destroy any personal data that had been accessed. They claim that the predictive tool is being implemented in the PDyRH system as support for the decision-making of the researchers and under the strategic plan of XXXX (as indicated, the implementation is scheduled for the first half of 2023).

- From the SEAV area, it is stated that it was known that the previous head of XXXXXXXX allowed the extraction and storage of documents on an official laptop without the knowledge of the officials who participated in the creation process of the predictive tool, and that this was not known by either the SEAV area or XXXX until the day after the laptop was stolen, on which date they learned that XXXXXXXX D. XX had stored information on said laptop owned by SES and that according to his own statements he also used it for other personal purposes and took it out of the facilities without any control.

- From the SEAV area, it is stated verbatim: "in the event that individuals who can interpret the content of the information access the information contained in the computer, the consequences would be unpredictable, since some of the reports known, according to the statements of XX, are from very high-profile cases, but already judged. That is to say, they do not refer to ongoing investigations."

- In the received documentation, it is stated by the SEAV area that the previous head of XXXXXXXX allowed the extraction and storage of documents on an official laptop and that these details were not known to the heads of XXXX until the day after the laptop was stolen. It is asserted that neither the SEAV officials nor the XXXX officials were aware that XXXXXXXX from UAM D. XX, who was working for XXXX through XXXX, was using an official laptop not only for the work of area XXXX but also for his classes at the University, for his doctoral thesis work, and other private uses, and according to the assertion of XXXXXXXX himself, no one warned him since his incorporation in 2017 that he could not do so.

In the received documentation, it is stated by the SEAV area that according to the voluntary statements made by user D. XX, the hard drive of the laptop contained at least the following information:

1. Police reports on resolved disappearances from both the National Police and Civil Guard as well as from the Autonomous Police Mossos d'Esquadra and the Foral Police of Navarra. It also contains databases in which the information from the aforementioned reports was recorded.
2. Police reports on homicides resolved both police and judicially and associated with a report of disappearance, from both the National Police and Civil Guard.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/37

Civil. It also contains databases in which the information from the aforementioned reports is recorded, as well as audio and video recordings of interviews with those involved in the cases (victims, aggressors, or their relatives among other aspects).

3. Annual extractions from the missing persons system XXXXXXXX.

4. It also contained two folders with material related to the previous information that was used for teaching and scientific research purposes.

7- List of preventive security measures to ensure the protection of personal data affected by the breach, as well as accreditation of the Risk Analysis conducted to conclude them. Specifically, those measures aimed at:

- o Ensuring access control to devices and user control.

- o Ensuring control of storage media containing personal data, specifically those that could be used outside the Ministry's facilities.

It responds that information provided by the SGSICS is attached in Annex II, indicating that the measures with which the SGSICS protects the managed portable devices are as follows:

1. Tool XXXXXXXXXXXX for threat detection and blocking, heuristic analysis, scheduled weekly scans, policies for controlling installed applications, policies for controlling devices that connect to laptops, malware prevention, web access control policies, and firewalls to control the access of laptop applications to the internet.

2. Tool XXXXXXXXXXXX to neutralize threats unknown to XXXXXXXX and prevent the execution of malicious files based on blacklists from XXXXXXXX.

3. Access protection to XXXX via password.

4. For storage media intended to be used outside the Ministry's facilities, the procedure is (...).

Regarding the stolen equipment, they state that it was included in a batch of six portable devices requested from the SGSICS to be used solely during internal training sessions and that they needed to have less security due to the nature of these courses, which was subsequently awarded on 29/11/2018 to the Head of XXXXXXXX in replacement of the one that was broken (as noted in the attached document reference 7), but that both the broken equipment and the awarded one were intended for internal use within the premises of the VGEF Area, and that the DGCE did not inform the SGSICS about the use of the device containing police information outside the SES premises. Given the specific characteristics of the courses, these devices were configured with the administrator user enabled for use by the individuals who would use them and without user access credentials. This request is recorded in the SGSICS incident manager with reference number XXXXXX, which is attached as Doc. 6.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

25/37

"Regarding the measures adopted by the SGSICS for the protection of storage media intended to be used outside the Ministry's facilities, the procedure is (...).

At this point, it should be noted that since the responsible parties at the center awarding the equipment did not inform or request any measures from the SGSICS for the protection of information or the device during its transfer or use of police information or containing personal data outside the premises of the Secretary of State for Security, the stolen laptop lacked disk encryption and a password in the BIOS. The Inspector notes as an observation, "The risk analysis carried out is not accredited either by the DGCE itself as data controllers or by the SGSICS as responsible for ensuring the security of the devices."

Information provided by the SGSICS is attached, Annex II.

8- List of all reactive security measures (technical and organizational) implemented after the detection of the breach, specifically those related to the encryption and anonymization of information.

It responds that information provided by the SGSICS is attached in Annex II. In it, it is stated:

"Coordinating with the DGCE, the procedures and technical and organizational security measures were reviewed and updated, resulting in the updated document 'Confidentiality Clause and Good Practices Regulation,' with an email sent by the VGEF Area for external staff (interns) to complete it to ensure that this document was received, signed, and returned to the Area for safekeeping, along with a request for an updated list of interns, indicating the start and end dates of their internships. A copy of the email is provided."

In the documentation received, Annex III of XXXX, it is stated that, as responsible for all actions carried out by the DGCE interns, the existing security protocols have been reviewed, and a series of actions have been immediately defined to improve security measures:

1. Centralization of the management of intern students (maintaining an updated list of agreements, actions for managing the physical use of spaces to improve personnel control).
2. Review and improvement of the confidentiality clause and document of good practices in the use of resources and procedures for action in the event of information loss, with the aim of improving awareness among personnel accessing protected data and providing guidance on behaviors that reduce the risk of breaches. Periodic review by the VGEF for improvement of controls.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/37

1. To control the release of information, the use or access to the facilities via mobile phones, laptops, or storage devices has been prohibited. To facilitate the custody of these items, the establishment of a cabinet has been requested.

2. External individuals performing work in the XXXX facilities:

3. They will only have access to pseudonymized data by code, and only the official responsible for the external individual will have access to the correlation data.

4. The work is carried out using an official laptop provided by XXXX, making it impossible to extract data, and it cannot leave the facilities.

"Regarding technical measures, the guidelines set by the General Subdirectorate of Information and Communications Systems for Security (SGSICS) are strictly followed, an entity that, according to RD 734/2020 of 4/08, is competent in this matter."

Annex VI of the DGCE dated 24/06/2022 is provided, addressed to SGSICS, requesting collaboration and cooperation to review various technical and organizational security measures of its own General Directorate and its areas that are being implemented, mentioning them in a way that guarantees an adequate level. Another document of the same date, addressed to the head of the SEAV area, which manages several files concerning the processing of personal data for which the General Directorate is responsible, requests collaboration and cooperation to review the processing of the PDYRH file and to collaborate with SGSICS to review risk levels and security measures, considering various and diverse measures that are enumerated.

The same type of document is addressed to the head of the Gender Violence, Studies, and Training Area.

9. A copy of the Data Protection Impact Assessment related to the processing activities affected by the breach, or justification for why it is not deemed necessary to carry it out, if applicable.

The Data Protection Delegation itself responded that: "A Data Protection Impact Assessment for the PDYRH processing has not been conducted, as the situation that led to the breach did not arise from formal data processing or the information system that supports it. However, all activities of processing carried out in the affected Areas have been legally reviewed, analyzed, and supplemented, and the documentation is attached in response to the preceding questions."

In the received documentation, ANNEX V, the response given on 26/09/2022 is also attached, titled: "Summary of the reactive measures adopted in the area of gender violence studies and training on

Personal Data Protection - Studies," by the HEAD OF THE VGEF AREA in response to the letter received from the Director of the DGCE and referenced in the previous point of the analysis. From this response, it is extracted:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

27/37

It is stated that since the collection, storage, and processing of data are necessary to carry out scientific research measures for the preparation of studies and reports that allow updating knowledge about various aspects of crime that facilitate its prevention and detection, as well as adequate training for professionals, the security protocols and information processing procedures have been reviewed. The actions taken have been:

1. The legal basis for the research activities is related in the completion of the new processing activities: "SES-STUDIES" and "SES-RESEARCH ACTIONS TREATMENTS" advertised in the Treatment Activities Registry (RAT) of the Ministerial Department. The purpose is to conduct scientific studies on crime aimed at the prevention and detection of offenses and, in general, to contribute to the improvement of public security policy.
 2. The Data Protection Impact Assessment (EIPD) has been prepared.
 3. The Confidentiality and Good Practices Clause has been reviewed and improved.
 4. Actions have also been implemented for the management of the physical use of spaces by collaborating external personnel.
 5. Assignment of a responsible tutor for students in internships, serving as a reference figure and liaison with Studies in case of doubts or incidents involving students.
 6. General rules for access and presence in the building. Logical access rules, responsible use of information systems, transfer of assets, and information incidents.
 7. Guide for the responsible use of resources, highlighting guidelines for the proper use of information systems, responsible use of email and Internet access, intellectual property, and the procedure for action in the event of possible information loss. All of this, when specific permissions exist for these actions.
 8. Preparation of an individual file for collaborating external individuals detailing the physical persons, authorizations, and accesses.
 9. It is stated that the follow-up of all the mentioned actions is planned, which will be reviewed periodically to maintain an updated risk map and improve the previously defined controls.
- In ANNEX IV, there is also a document that refers, without date and without author reference, adding to the above that "by the Studies of this VGEF area, responsible for coordinating all actions related to students in internships, the existing security protocols have been reviewed following the breach, and actions have also been taken."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

28/37

immediate action will be taken to define a series of reactive measures aimed at improving existing security measures, specifically:

1. The management of intern students has been centralized, and updated lists of students will be maintained, which will allow for increased control and monitoring:
2. A review of agreements will be carried out so that access can only be granted through updated agreements with the relevant universities and within established deadlines.

10- In relation to the National Security Scheme:

- o Description of the information systems affected by the breach and their security category.
- o Copy of the Statement of Applicability containing the list of measures implemented in the information

systems affected by the breach.

o Copy of the report from the last audit conducted on the information systems affected by the breach to verify compliance with the requirements of the ENS.

The response is provided with the information attached by the SGSICS, ANNEX II.

They state that the information stolen and provided by this Subdirectorato corresponded solely to the comprehensive tracking system for cases of gender-based violence VioGén. It specifies:

- the "categories of interested parties":

"Individuals who are victims of acts that may be classified as gender-based violence and individuals involved in judicial proceedings and investigations related to those same acts."

- the description: "categories of personal data": criminal records of the alleged perpetrators and their prison status, related to the granting of permits or release (conditional or definitive) of inmates who are subject to judicial measures of distancing or prohibition of communication with the victim. As well as all those who are sentenced to penalties or alternative measures other than imprisonment. Identifying data: DNI/NIF/passport, as well as other identity documents, photographs, addresses, phone numbers, email addresses, vehicles.

Personal characteristic data: Data of filiation, related persons, date and place of birth, sex, nationality, employment status, health data, profession, educational level, and marital status. Data of an assistance and support nature for the victims that appear in the files prepared by the different services and bodies that provide services to victims of gender-based violence.

Regarding the statement of applicability that contains the list of measures implemented in the information systems affected by the breach, they indicate that "since the VioGén system is a police system not covered by the scope of application of the

29/37

Royal Decree 3/2010, of January 8, which regulates the National Security Scheme in the field of Electronic Administration (ENS), does not correspond to a system mentioned in Article 2 of Law 11/2007, of June 22, on electronic access of citizens to public services. Furthermore, until the new publication of the ENS (May 2022), the aforementioned systems were not expressly included within the scope of application of the ENS. It is at this moment, based on the new wording of the ENS, that the Security Plan is being developed with measures adjusted to the new ENS. Therefore, there is no Declaration of Applicability regarding the VioGén system based on the ENS.

Regarding the copy of the report from the last audit conducted on the information systems affected by the breach to verify compliance with the requirements of the ENS, it is stated that the latest audit conducted on the VioGén system is attached as Annex referenced as Doc. 9, although it is not provided, and they reiterate that they have no responsibility concerning the remaining information that was stored on the stolen laptop, such as that belonging to the PDyRH system.

1. Updated information regarding whether you are aware of the use by third parties of the personal data obtained through the breach.

The data controller states that, to date, they have no knowledge of the use by third parties of the personal data leaked from the laptop.

From the documentation received in response to our request, it is also confirmed that on this same day, June 24, 2022, the director of the DGCE sent another letter addressed to both the head of the SEAV Area, the head of the VGEF Area, and the Deputy General Director of the SGSICS with the following content:

"In accordance with the work carried out as a result of the security incident that occurred on May 4, following the recommendations and criteria of the Data Protection Officer of the Secretary of State for Security...

It is necessary to review the entire flow of data and treatments carried out in the PDYRH file so that all activities carried out are analyzed and documented, ensuring compliance with the general principles of processing. If deemed necessary, they should be included in the appropriate documentation and publicized in accordance with applicable legislation. Likewise, in coordination with the General Subdirectorato of Information and Communication Systems for Security, to the extent that it concerns them, all technical and organizational security measures should be reviewed based on possible risk

levels to ensure an adequate level of protection for personal data.

Specifically, except in legally authorized cases, it must be ensured that external individuals collaborating with your Area in the development of any activity, regardless of their status based on the appropriate legal instrument, do not have access to data that has not been previously anonymized or pseudo-anonymized, do not use official email accounts (generic or personal), or engage with third parties through any technological tool that may lead to confusion regarding their functions or duties in this organization (email, shared repository, etc.)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/37

They will also not have access to information that is not essential for their duties, and any action in this area must be guided by the principle of "need to know."

As specific security measures that must be verified as being implemented in these cases, at least the following will be found:

1. This external personnel, specifically if they are conducting any training practice, must be singularly supervised by personnel who can certify what they are doing, how they are doing it, where they are doing it, and for whom they are doing it. This way, it can be guaranteed at all times what specific task they are performing.
2. The control of (...) of this personnel in the facilities must be ensured.
3. The (...) must be provided, and access to areas or zones not authorized for this personnel is not permitted.
4. No use of (...) will be allowed, extending from access to disconnection.
5. They may not use (...) except to carry out their duties, and access to any page, development, or system that does not correspond to their activity is not permitted.
6. They may not use (...) related to their duties.
7. No use of (...) of any kind.
8. No connection of (...), it must be done under the supervision of the SGSICS.
9. No use of (...).
10. No use of (...) and/or containing personal data.
11. No use, utilization, or any activity based on (...) outside the facilities.

Similarly, the need for all personnel to be informed and aware of data protection matters is reiterated, emphasizing the obligations to communicate incidents or security breaches in accordance with the established protocols for all bodies dependent on the Secretary of State for Security. In any case, any security incident affecting personal data must be reported to the corresponding Data Controller and the DPO as soon as possible and always within 72 hours of becoming aware of it. I communicate this for the aforementioned purposes, requesting that all actions taken be forwarded to the DPO of the Secretary of State for Security for analysis and evaluation.

In ANNEX III of XXXX dated 4/10/2022, it is indicated that there is no knowledge of the use by third parties without authorization of the personal data stored on that computer.

11) On 6/02/2023, a request for information was made addressed to the XXXXXX of the Autonomous University of XXXXXX (XXXX), the contractor of the contract signed with the SES. On 22/02/2023, a response was received with the following information:

- The XXXX was awarded the research contract file 000000XXP027, for which Mr. XX was hired at the request of SES itself, as he had already been working with the data subject to the contract and had experience in its analysis, and Ms. XX. A copy of the employment contracts of both workers with a signing date of 30/06/2021 is provided.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/37

- They assert that it was agreed with the SES that the personnel assigned to this contract would carry out all work in the facilities located at ***ADDRESS.2 in Madrid and with computer equipment owned by the SES, since the information subject to the study was considered specially protected data. They claim that no work was carried out outside the SES facilities or with the researchers' own equipment, nor that of XXXX. Therefore, at the end of the contract, the destruction or return of personal data was not warranted as they were on equipment that was not owned by XXXX.
- They assert that the data was never extracted from the SES equipment and that they are unaware of how it was possible for a laptop containing sensitive data to be stolen from the aforementioned user on 4/05/2022. They claim that this situation cannot be linked to the actions of XXXX as the contractor, since the contract ended on 31/12/2021 and no subsequent relationship was maintained with any of the contracted individuals. They provide a document sent to the two contracted individuals notifying them of the termination of the contract as of that date, "the employment relationship being terminated from this date."
- They assert that at no time did the General Directorate of Coordination and Studies communicate to XXXX at the end of the contract (nor to the two researchers authorized to execute the services) the obligation to destroy the data, nor was this communicated prior to the payment of the invoice. They also state that they are unaware of which device contained the data that was stolen on 4/05/2022.
- They assert that the person responsible for the contract did not provide the researchers of XXXX, nor XXXX itself, with documentation, policies, or information regarding the technical and organizational measures that the researchers were required to comply with in the execution of the contract.
- They assert that all personnel of XXXX receive documentation related to the processing of personal data and training in this area upon their incorporation. As proof of this, they provide the document Security Policy of XXXX and the document "Employee Confidentiality Commitment" signed by the researchers contracted for this contract, (...) on 30/06/2021. From this last document, the following content stands out:
 "... You undertake the commitment to maintain professional secrecy regarding personal data, data about clients, commercial and organizational strategies, industrial information, and any other information to which you have access due to the assigned functions; this obligation will continue in compliance with Article 32 of the GDPR, even after the employment relationship ends.
 Under no circumstances should you incorporate your personal information into the computer systems...

Likewise, in accordance with Article 32 of the GDPR, as an employee, you commit to comply with the internal security rules that affect the performance of your functions, as well as the use of computer equipment, email, and other applications to which you will have access. Similarly, as a necessary part of this, you have the responsibility and duty to carry out the training programs and apply the procedures and rules that are communicated to you for this purpose."

- They provide a copy of the Record of Processing Activities for contracts awarded between the years 2020 and 2023 as data processors.
- They provide the designation of the Data Protection Officer and the communication of this to this Agency.

THIRD: Initiation of sanctioning procedure.
 On 8/05/2023, it was agreed by the Director of the AEPD:
 "TO INITIATE SANCTIONING PROCEDURE against (...), with NIF XXXXXXXXX, for the alleged infringement of the GDPR in the following articles:
 - Article 25 of the GDPR, in accordance with Article 83.4.a) of the GDPR, classified as serious for the purposes of prescription in Article 73.d) of the LOPDGDD.
 - Article 32 of the GDPR, in accordance with Article 83.4.a) of the GDPR, classified as serious for the purposes of prescription in Article 73.f) of the LOPDGDD.
 - Article 33 of the GDPR, in accordance with Article 83.4.a) of the GDPR, classified as minor for the purposes of prescription in Article 74.m) of the LOPDGDD.
 - Article 34 of the GDPR, in accordance with Article 83.4.a) of the GDPR, classified as minor for the purposes of prescription in Article 74.ñ) of the LOPDGDD.
 "for the purposes provided in Article 64.2 b) of Law 39/2015, of 1/10, on the Common Administrative

Procedure of Public Administrations, (hereinafter, LPACAP), the sanctions that may correspond would be a warning for each infringement, without prejudice to what results from the instruction."

FOURTH: Allegations to the initiation agreement.

Against the initiation agreement, on 29/12/2023, allegations were received, stating:

1- A formal notification document of the initiation agreement of PS/00128/2023 has been received, addressed to the Ministry of the Interior, NIF XXXXXXXXXX, "as there is no record of the receipt of the notification of the opening agreement, electronically signed by the director of the AEPD on 8/05/2023," "therefore we proceed to resend it," stating that "this has not been recorded in the SES, the DGCE, nor in any of its dependent bodies or units."

They state that all of this, when the communication of the breach and the holder of the treatments correspond to the indicated governing body of the DGCE, with its own NIF: XXXXXXXXXX, also of the SES. Based on the fact that their DGCE has the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/37

responsibility for the processing, as indicated in the RAT, as the governing body of the SES, which exercises the legally attributed competencies, and in accordance with Article 28.1 of Law 40/2015 of 1/10, only those who are found responsible for the infringements can be declared liable, it is estimated that responsibility cannot be attributed to the Ministry of the Interior as a whole for the conduct of the commission subject to the file. It is "necessary to modify the agreement to initiate the procedure for the exercise of the sanctioning power, under penalty of understanding the procedure null and void in accordance with the content of Article 47 of Law 39/2015, of 1/10, on the Common Administrative Procedure of Public Administrations." It points out that previously, in prior actions, a request for information was also sent to the NIF of the Ministry of the Interior on 16/09/2022, and it was answered by the DGCE on 6/10/2022.

2- Considers that the period of prior actions would have been exceeded, both on the date of signing the initiation agreement and when the communication is legally effective, through the notification that occurs on 20/12/2023. "It would be appropriate to formulate a new initiation of the investigation period and, based on the result, the formulation of a new initiation agreement for the sanctioning procedure," since otherwise, it could be understood as null, in accordance with Article 47 of the LPACAP.

3- Estimates that the data processing was being carried out "directly by a competent authority within the scope of application of Article 4 of the aforementioned LO 7/2021, it was necessary and its purpose was the prevention and possible detection of criminal offenses," which differs from the opinion of the AEPD to apply the GDPR, and not the LO 7/21. Applying the reasoning set forth would "make it materially impossible to develop specific police tools by the bodies of the Department for the Forces and Security Corps or the other competent authorities, since Article 6.2 of the LO 7/21 does not allow the transfer to entities that are not considered competent unless provided for by internal law or EU law." The operations were being carried out by the areas of the DGCE with the aim of achieving a technical tool to prevent and detect crimes.

4- Regarding the imputation of Article 25 of the GDPR, it states that "the treatments that were affected were already included as declared and registered files in Order INT/1911/2007 of 26/06: 'domestic and gender violence' in the Ministry of the Interior, and subsequently in Order INT/1202/2011 of 4/05," in which the SES is listed as the responsible party for the file.

5- States that "These are not new treatments with the possibility of privacy by design and by default from prior planning to the effective execution of the operations since they had been in force and operational for decades. The security measures were implemented in accordance with the content of the then applicable Royal Decree 1720/2007, of 21/12, which approves the Regulation for the development of Organic Law 15/1999, of 13/12, on the protection of personal data."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

34/37

6- Regarding the conduct attributed as an infringement of Article 32 of the GDPR, it indicates that it reproduces the response and control measures communicated to the AEPD in the prior actions. It summarizes the security measures implemented, indicating that technical measures have been reinforced by applying Zerotrust policies by default, designing a workstation with greater security measures and centralized control through "Microsoft Endpoint Configuration Manager," which allows for constant monitoring of the security status of the IT infrastructure and immediate action in case of security incident detections. Specifically, it refers to:

“(…):

1. XXXXXXXX at startup

2. User and Password of the XX

- All equipment complies with the security policy: Update and control of installed software, for which the functionality of iTunes of M365 is used, with which (...). Deployment of XXXXXXXXXXXX

Configuration XXXXXXXXXXXXXXXX with the following objectives:

1. Detect XXXXXXXXX activity of users and devices (...).

2. Protect the (...).

3. Obtain clear and real-time information on the timeline of attacks to respond quickly.

4. Monitor multiple entry points through integration with (...).

- Deployment via GPO of (...).”

7- Regarding the conduct of possible non-compliance with Article 33 of the GDPR, Article 38 of the LO 7/21, considering it minor, it should be understood as prescribed. It adds that the communication was made by the responsible party immediately after the technical unit investigating the incident confirmed that personal data could be involved.

8- Regarding the conduct of possible non-compliance with Article 34 of the GDPR, Article 39 of the LO 7/21, considering it minor, it should be understood as prescribed. It adds that the processing that covered these actions falls within the scope of the LO 7/21, so under the application of Article 39.5, it was not necessary to make the communication.

LEGAL GROUNDS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/37

I Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II Expiration of the procedure

In the initiation agreement, it was indicated: "The procedure shall have a maximum duration of 9 months from the date of the initiation agreement or, where applicable, from the draft initiation agreement. Upon the expiration of this period, it will expire, and consequently, the proceedings will be archived; in accordance with the provisions of Article 64 of the LOPDGDD."

Article 63 of the LOPDGDD, which is framed in Title VIII "Procedures in the event of a possible violation of Data Protection regulations," states:

"1. The provisions of this Title shall apply to the procedures processed by the Spanish Agency for Data

Protection in cases where an affected party claims that their request to exercise the rights recognized in Articles 15 to 22 of Regulation (EU) 2016/679 has not been addressed, as well as in cases where it investigates the existence of a possible infringement of the provisions of the aforementioned regulation and this organic law.

2. The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

The initiation agreement was signed on May 8, 2023, and the period for its resolution, which would have occurred on February 8, 2024, had not taken place. Applying Article 21.1 of the LPACAP, it results:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

36/37

“1. The Administration is obliged to issue an express resolution and to notify it in all procedures, regardless of their form of initiation.

In cases of prescription, waiver of the right, expiration of the procedure, or withdrawal of the request, as well as the subsequent disappearance of the object of the procedure, the resolution shall consist of the declaration of the circumstance that occurs in each case, indicating the facts produced and the applicable norms.”

Considering the effects provided for in Article 25 of the same regulation, which states:

“1. In procedures initiated ex officio, the expiration of the maximum period established without an express resolution being issued and notified does not exempt the Administration from the legal obligation to resolve, producing the following effects:

b) In procedures where the Administration exercises sanctioning powers or, in general, intervention powers, which may produce unfavorable effects or burdens, expiration will occur. In these cases, the resolution declaring the expiration will order the archiving of the proceedings, with the effects provided for in Article 95.”, which states:

“3. Expiration will not, by itself, produce the prescription of actions by the individual or the Administration, but expired procedures will not interrupt the prescription period.

In cases where it is possible to initiate a new procedure because the prescription has not occurred, the acts and procedures whose content would have remained the same had the expiration not occurred may be incorporated into it. In any case, in the new procedure, the procedures for allegations, evidence proposal, and hearing of the interested party must be completed.”

In accordance with the above, the Director of the Spanish Agency for Data Protection
RESOLVES

FIRST: To declare the expiration of the procedure initiated against the GENERAL DIRECTORATE OF STUDY COORDINATION (SECRETARY OF STATE FOR SECURITY - MINISTRY OF THE INTERIOR) with NIF S2800109G for the infringements of Articles 25, 32, 33, and 34 of the GDPR.

SECOND: TO NOTIFY this resolution to the GENERAL DIRECTORATE OF STUDY COORDINATION (SECRETARY OF STATE FOR SECURITY - MINISTRY OF THE INTERIOR) with NIF S2800109G.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

37/37

THIRD: TO COMMUNICATE this resolution to the OMBUDSMAN, in accordance with the provisions of Article 77.5 of the LOPDGDD.

FOURTH: In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties. Against this resolution, which concludes

the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of 13/07, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of 1/10. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es